

USDT0 · SECURITY REVIEW

USDT0

Stable Wrappers.

A security review of Stable Wrappers.

CLIENT	PROJECT	AUDITORS	AUDIT WINDOW	FINAL REPORT
USDT0	Stable Wrappers	Guardian	March 31 – April 2, 2025	April 9, 2025

§ 00

Contents.

15 pages — overview, confidence ranking, scope, 6 findings, disclaimer, and about Guardian.

§ 01	Overview	P. 03
§ 02	Confidence Ranking	P. 04
§ 03	Scope & Classifications	P. 05
	Files in Scope	P. 06
§ 04	Findings	P. 07
	Main Review · 6 findings	P. 08
§ 05	Disclaimer	P. 14
§ 06	About Guardian	P. 15

§ 01

Overview.

Guardian reviewed Stable Wrappers across a single review round. The final report includes 4 Low, 2 Informational findings.

AUDIT FIRM	METHODOLOGY
Guardian	Smart contract · Manual · Main Review
CLIENT	
USDT0	
PROJECT	
Stable Wrappers	
PREPARED BY	
Guardian	
AUDIT WINDOW	
March 31 – April 2, 2025	
FINAL REPORT	
April 9, 2025	

1.1 Confidence Ranking

5 / 5

Very High Confidence

Guardian assigns a Confidence Ranking of 5 out of 5, combining finding severity, remediation outcome, and the reviewer’s assessment of latent risk. The full scale is on the next page.

1	2	3	4	5
VERY LOW CONFIDENCE	LOW CONFIDENCE	MODERATE CONFIDENCE	HIGH CONFIDENCE	VERY HIGH CONFIDENCE

1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	ACK	PARTIAL	RESOLVED
Critical	0	0	0	0	0
High	0	0	0	0	0
Medium	0	0	0	0	0
Low	4	0	4	0	0
Informational	2	0	2	0	0
All severities	6	0	6	0	0

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence ASSIGNED	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence	Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity findings.
3 Moderate Confidence	Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.	Some High/Critical findings, with various Medium severity findings.
2 Low Confidence	Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.	Over 6 High and Critical findings across the engagement.
1 Very Low Confidence	The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.	Over 12 High and Critical findings across the engagement.

§ 03

Scope & Classifications.

Guardian reviewed Stable Wrappers.

3.1 Severity Matrix

	IMP · HIGH	IMP · MED	IMP · LOW
LIK · HIGH	Critical	High	Medium
LIK · MED	High	Medium	Low
LIK · LOW	Medium	Low	Low

IMPACT · HIGH

Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.

IMPACT · MEDIUM

Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.

IMPACT · LOW

Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.

LIKELIHOOD · HIGH

Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.

LIKELIHOOD · MEDIUM

Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.

LIKELIHOOD · LOW

Unlikely to ever occur in production.

Files in Scope.

FILE	NSLOC	TOTAL
No files were recorded in scope.		

§ 04

Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
MAIN REVIEW					
L-01	Absence Of quoteSend Implementation In OStableWrapper	Code Best Practices	LOW	ACKNOWLEDGED	p. 8
L-04	Potential IzCompose Decoding Failure	Warning	LOW	ACKNOWLEDGED	p. 9
L-05	IzCompose Token Lock Risk	Warning	LOW	ACKNOWLEDGED	p. 10
L-06	withdrawToWithPermit() can be blocked	Warning	LOW	ACKNOWLEDGED	p. 11
L-02	depositToAndCall is not EIP677 compatible	Code Best Practices	INFORMATIONAL	ACKNOWLEDGED	p. 12
L-03	IzToken payments are not supported	Warning	INFORMATIONAL	ACKNOWLEDGED	p. 13

LOW **L-01**

ACKNOWLEDGED

Absence Of quoteSend Implementation In OStableWrapper

CATEGORY Code Best Practices
LOCATION OStableWrapper.sol
REVIEW Main Review

DESCRIPTION

The `OStableWrapper` contract provides a `send` function to facilitate cross-chain transfers via LayerZero's OFT. However, it does not implement a `quoteSend` (or equivalent) function to allow users or integrators to estimate fees or amounts prior to sending. Typically, LayerZero OFT contracts and wrappers expose `quoteSend` or a similar mechanism so that off-chain services and dApps can easily query the bridging costs or token amounts in advance.

Without `quoteSend`, developers or end users cannot directly compute how much native token or messaging fee they will need to attach to the send call and they would be forced to query the `oft` contract `quoteSend` function directly.

RECOMMENDATION

Add a `quoteSend` function at the `OStableWrapper` level that internally calls the OFT's own quoting interface.

RESOLUTION

Status: Acknowledged.

LOW **L-04**

ACKNOWLEDGED

Potential IzCompose Decoding Failure

CATEGORY	Warning
LOCATION	StableComposer.sol
REVIEW	Main Review

— DESCRIPTION

The IzCompose function in the StableComposer contract expects the encoded compose message to include the recipient address. If the address is missing or incorrectly formatted, the call may fail during decoding, leaving the funds locked in the StableComposer contract.

— RECOMMENDATION

Document this and consider implementing UI validations to ensure the correct format is used in the encoded compose message, preventing potential issues.

— RESOLUTION

Status: Acknowledged.

LOW **L-05**

ACKNOWLEDGED

IzCompose Token Lock Risk

CATEGORY	Warning
LOCATION	StableComposer.sol
REVIEW	Main Review

— DESCRIPTION

The IzCompose function in the StableComposer contract is payable but calls the non-payable withdrawTo function as part of its logic. As a result, any native tokens sent to IzCompose effectively remain in the contract and are locked.

— RECOMMENDATION

Add validation to ensure that msg.value is zero, or document this to make sure executors are aware that native tokens may be locked if sent to the contract.

— RESOLUTION

Status: Acknowledged.

LOW **L-06**

ACKNOWLEDGED

withdrawToWithPermit() can be blocked

CATEGORY	Warning
LOCATION	OStableWrapper.sol: 91
REVIEW	Main Review

— DESCRIPTION

A malicious user can frontrun the call to `OStableWrapper.withdrawToWithPermit()` function with a direct call to `token.permit()`. This will make the `permit()` call in the `OStableWrapper` revert because the signature is already consumed. In result, withdrawals via `withdrawToWithPermit()` can be blocked.

— RECOMMENDATION

Consider wrapping the `permit` call in a `try/catch`

— RESOLUTION

Status: Acknowledged.

INFORMATIONAL L-02

ACKNOWLEDGED

depositToAndCall is not EIP677 compatible

CATEGORY	Code Best Practices
LOCATION	0StableWrapper.sol: 68
REVIEW	Main Review

DESCRIPTION

According to [EIP-677](https://github.com/ethereum/EIPs/issues/677), the `from` argument of `onTokenTransfer()` should be the address which just transferred the tokens to the recipient. In the case of `0StableWrapper.depositToAndCall()`, that's the `0StableWrapper` itself, but the address passed to `onTokenTransfer()` is the `msg.sender`. This makes the wrapper not fully EIP677 compatible.

RECOMMENDATION

To make the wrapper EIP677 compatible, you can implement the following change:

- `return ITransferReceiver(recipient).onTokenTransfer(msg.sender, amountOut, data);`
- `return ITransferReceiver(recipient).onTokenTransfer(address(this), amountOut, abi.encodePacked(msg.sender, data));`

RESOLUTION

Status: Acknowledged.

INFORMATIONAL L-03

ACKNOWLEDGED

lzToken payments are not supported

CATEGORY	Warning
LOCATION	0StableWrapper.sol
REVIEW	Main Review

DESCRIPTION

`0StableWrapper.send()` accepts a `MessagingFee` parameter which may have `lzTokenFee > 0`. In this case, the OFT will try to pay with lz tokens by transferring them from the wrapper, but since it hasn't approved the OFT, the transaction will be reverting.

RECOMMENDATION

At the moment, the endpoint on the Stable chain hasn't enabled `lzToken` payments so it's enough to document the issue and keep in mind that a new wrapper has to be deployed in the future if the payment method is enabled and the team want to use it.

RESOLUTION

Status: Acknowledged.

§ 05

Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

\$45B+DIGITAL ASSETS UNDER
REVIEW**200+**

ENGAGEMENTS COMPLETED

500+CRITICAL & HIGH FINDINGS
REPORTED

Reach us at audits@guardianaudits.com.